PROJECT UDYAM DIGITAL · YTL HACKATHON 2026 · TRACK A

# Data privacy and security: design note

The journey handles business registration documents, signatory ID, address proof and contact details. These are the choices built into the design, aligned with the DPDP Act, 2023. All data in the prototype is synthetic; the same controls apply in production.

## 1 Consent first, per purpose

- A consent screen in the owner's language appears **before any registry lookup or document upload**. It says what is fetched, from where and why.
- Consent is recorded per purpose (identity check, install address, billing). Withdrawing it is as easy as giving it, from the tracker.
- Refusing consent never blocks silently: the journey falls back to a manual KYC path.

## 2 Collect only what each step needs

- The advisor asks for city, size, sites and current setup. **Never PAN, date of birth or income.**
- KYC takes four documents and nothing more. Registry lookups return only the fields needed to auto-fill and validate; full records are not stored.
- KYC data is never reused for marketing, and the recommendation engine cannot read it.

## 3 Identifiers and documents

- GSTIN, Udyam and ID numbers are **masked in every screen and log** (for example 32XXXXXXXXXT1ZW). Full values live only in the encrypted KYC store.
- Documents are encrypted in transit and at rest. Access is role-scoped: partners see status, not documents.
- Automated checks (checksum, registry status, name match, 90-day bill) reduce fraud and human exposure to sensitive files.

## 4 GenAI safeguards

- The LLM receives a masked profile and eligible bundle IDs only. It never sees prices, SKUs, identifiers or document images.
- OCR runs inside our own cloud environment; no document goes to an external model.
- The rules engine rejects any model output that changes eligibility, price or consent. Chat logs are anonymised before review.

## 5 Retention (proposed, to confirm with compliance)

- **Document images:** deleted 30 days after the KYC decision.
- **Verification result, masked IDs and consent record:** kept for the contract term plus the period counsel confirms.
- **Advisor chat logs:** anonymised, kept 12 months. Scheduled jobs purge on these dates.
- These are design choices, not asserted legal requirements.

## 6 Rights, accountability, limits

- Owners can view, correct and erase their data from the tracker. A named grievance officer is shown on the consent screen.
- A breach runbook covers notifying the regulator and affected owners.
- **We did not build:** cross-purpose profiling, third-party data sharing, or dark patterns. Mocked registries stand in for consent-based GSTN, Udyam and DigiLocker APIs.

> **Consent screen, as shown to the owner:** "We collect your GST and Udyam certificates, signatory ID and one address proof, only to verify your business and activate your lines. Nothing is used for marketing. Original documents are deleted 30 days after the decision. You can withdraw consent or ask for deletion anytime in this app."